

Docker SBOM:

Keeping a Check on Security Risks

The Log4j vulnerability and SolarWinds supply chain attack have made us realise that software supply chains are at great risk of being targeted by attackers. The Docker SBOM helps detect these risks.



Software supply chain security comprises everything required to build, deliver and run software anywhere with confidence. It ensures that not only software but the infrastructure, operating systems, source code repositories, registries, developers who wrote it, and the cloud services it uses don't pose any threats.

The Software Bill of Materials (SBOM) has emerged as the first step to ensure software security.

What is SBOM and how does it help businesses?

An SBOM is a list of software components that build the software product. It details the software package, content, licence, and certificate information, just like packaged food items contain ingredients and other information.

SBOMs help organisations know and keep track of all software components along with other details, such as:

- Determining all the runtime dependencies of the software
- Keeping track of critical updates and patches
- Reducing supply chain attacks and ensuring the organisation doesn't use vulnerable components
- Detecting licence and certificate-related issues

The National Telecommunications and Information Administration (NTIA) has listed the minimum requirements for the SBOM, which are:

- Software supplier and author of SBOM
- Information about software vendors
- Software component name and its version
- Unique identifier for each component